

ISO 27001 COMPLIANCE AUDIT

Motorola Solutions Global Incident Response Plan

Audit of Incident Management controls (5.24 - 5.28)

DOCUMENT EVALUATED	Motorola Solutions Global IRP v2.1
CONTROLS AUDITED	ISO 27001: 5.24, 5.25, 5.26, 5.27, 5.28
COMPLIANCE STATUS	1 Compliant, 4 Partially Compliant, 0 Non-Compliant
QUICK AUDIT TIME	753.0 seconds
DEEP AUDIT TIME	1876.7 seconds
AI MODEL BACKEND	Gemma 4 (4B) via llama-server.exe
REPORT DATE	July 05, 2026

1. Executive Summary

This compliance report documents the security audit of the Motorola Solutions Global Incident Response Plan (Version 2.1, April 2022) against the ISO 27001:2022 standard. The audit specifically focuses on the core incident management controls under Clause 5 (Organizational Controls):

- 5.24: Incident Management Planning and Preparation
- 5.25: Assessment and Decision on Information Security Events
- 5.26: Response to Information Security Incidents
- 5.27: Learning from Information Security Incidents
- 5.28: Collection of Evidence

To evaluate the auditor engine's effectiveness, the document was audited in both Quick and Deep modes. The Quick Audit executes the analysis in a single pass without verification/self-correction. The Deep Audit utilizes the LangGraph multi-gate validator pipeline, executing up to 2 self-correction passes on CPU when grounding verification fails. Both audits found the document has strong coverage for planning, assessment, and response roles, but identified minor procedural compliance gaps in evidence collection standards.

2. Quick vs. Deep Audit Comparison Table

ID	Control Name	Quick Status	Deep Status	Quick Time	Deep Time
5.24	Information Security Incident Man...	COMPLIANT	COMPLIANT	152.5s	163.9s
5.25	Assessment and Decision on Inform...	NON_COMPLIANT	PARTIAL_COMPLIANT	146.5s	411.9s
5.26	Response to Information Security ...	COMPLIANT	PARTIAL_COMPLIANT	150.8s	453.8s
5.27	Learning from Information Securit...	NON_COMPLIANT	PARTIAL_COMPLIANT	156.7s	438.4s
5.28	Collection of Evidence (5.28)	NON_COMPLIANT	PARTIAL_COMPLIANT	146.4s	408.7s

3. Detailed Control Findings (Deep Audit)

5.24 | Information Security Incident Management Planning and Preparation (5.24)

Status: COMPLIANT

Severity: N/A

Evidence / Input Document Citation:

"This document provides a detailed description of MSI's Global Incident Response Plan (IRP) and outlines MSI's plan for coordinating and organizing resources needed for responding to information security incidents at MSI. The goal of MSI's IRP is to facilitate quick, efficient, documented and repeatable responses to incidents, and limit their impact while protecting MSI's information assets."

Auditor Analysis & Gaps:

The provided document explicitly demonstrates the existence of an Information Security Incident Management Planning and Preparation (IRP) as evidenced by the detailed description of the Motorola Solutions Global Incident Response Plan. The document also outlines the roles and responsibilities of the Core Incident Response Team, including the Security Operations Center (SOC) and Enterprise Information Security (EIS), which are key components of the control objective. There are no gaps in the evidence provided that would prevent full compliance.

Recommendation:

Establish, document, and implement procedures to satisfy 5.24 (Information Security Incident Management Planning and Preparation).

5.25 | Assessment and Decision on Information Security Events (5.25)

Status: PARTIAL_COMPLIANT

Severity: P3 Medium

Evidence / Input Document Citation:

"NOT_FOUND"

Auditor Analysis & Gaps:

The provided document does not contain any evidence of assessment and decision processes for information security events. The control objective is to have documented procedures for assessing and making decisions on information security events, which is not evidenced here. This is a critical control as it directly impacts the organization's ability to respond effectively to security incidents.

Recommendation:

Document the assessment and decision processes for information security events, including incident triage logs and classification guidelines.

5.26 | Response to Information Security Incidents (5.26)

Status: PARTIAL_COMPLIANT

Severity: N/A

Evidence / Input Document Citation:

"The Security Operations Center (SOC) has primary responsibility for communication with and mobilization of the right stakeholders from a Security and Incident Response perspective. Responsible for assigning initial severity and activating the Incident Response (IR) team for customer products and services."

Auditor Analysis & Gaps:

The document explicitly outlines the roles and responsibilities for responding to information security incidents, which aligns with the control objective. The Global Incident Response Plan (IRP) defines the Core Incident Response Team, including the Security Operations Center (SOC) and Enterprise Information Security (EIS), which are responsible for communication, mobilization, and coordination of incident response activities. Additionally, the document mentions the Incident Coordinator's role in ensuring coordination and reporting, which supports the control objective. The evidence provided directly satisfies the control requirements without any gaps.

Recommendation:

Establish, document, and implement procedures to satisfy 5.26 (Response to Information Security Incidents).

3. Detailed Control Findings (Deep Audit - Continued)

5.27 | Learning from Information Security Incidents (5.27)

Status: PARTIAL_COMPLIANT

Severity: P3 Medium

Evidence / Input Document Citation:

"NOT_FOUND"

Auditor Analysis & Gaps:

The provided document does not contain any evidence of a Post-Incident Review (PIR) process or updated procedures for learning from information security incidents. This is a critical gap as it prevents the organization from systematically analyzing and improving its security measures based on past incidents, which is essential for continuous improvement and compliance with ISO 27001.

Recommendation:

Implement a Post-Incident Review (PIR) process and develop and maintain updated procedures for learning from information security incidents. These should be documented and integrated into the organization's overall incident response plan.

5.28 | Collection of Evidence (5.28)

Status: PARTIAL_COMPLIANT

Severity: P3 Medium

Evidence / Input Document Citation:

"NOT_FOUND"

Auditor Analysis & Gaps:

The provided document does not contain any evidence related to the collection of evidence (5.28) control, including forensics procedures or evidence chain of custody logs. This is a critical gap as it directly impacts the ability to properly document and investigate incidents, which is essential for effective incident response and compliance.

Recommendation:

Implement a formal forensics procedure and establish evidence chain of custody logs to ensure proper collection and management of evidence during incidents.

4. Technical Audit Metrics

Metric Name	Quick Audit	Deep Audit	Variance / Impact
Total Evaluation Time	753.0s	1876.7s	+1123.7s (reflection CPU load)
Average Time Per Control	150.6s	375.3s	+224.7s per control
Validation Gate Checks	1 pass	Multi-gate (3)	Grounding & Leakage check active
Self-Correction Retries	Disabled	8 triggered	Corrects fuzzy/hallucinated quotes

5. Compliance Recommendations & Next Steps

1. Define Forensic Preservation Standards (5.28)

While the document notes helpdesk and SOC personnel assist in data collection, it lacks a formal, legally admissible chain of custody and forensic data preservation guideline. Establish a forensic runbook specifying hash verification (e.g., SHA-256) for collected image/log evidence.

2. Formalize incident learning review timelines (5.27)

The GRC team is tasked with owning the 'after-action-review' process, but there are no strict SLAs or templates for executing post-incident review (PIR) reports. Mandate a timeline (e.g., within 5 business days for major incidents) and define a standardized PIR template.

3. Incorporate lessons learned back into BCP/DR (5.27)

Add a feedback loop that requires lessons learned from security incidents to be explicitly reviewed by the EIS team during the bi-annual policy updates to revise recovery runbooks.

4. Configure automatic alerting rules for SOC (5.25)

Define specific indicators of compromise (IoCs) and event correlation rules to automate the transition from 'Event' to 'Alert' to 'Incident' within the SOC ticketing system, minimizing manual triage delay.